

Product Safety Risk Management Matrix

PostgreSQL Database Design Specification

Version 1.0 | Final design package | 10 September 2026

Source basis

Product safety risk management matrix template 26.3.xlsx, with primary emphasis on the RMM - Guidance tab and supporting controlled-list tabs.

Design objective

Create an audit-ready, normalized, revision-controlled information model for risk traceability from hazard and hazardous situation through harm, initial risk, risk controls, implementation/effectiveness evidence, and residual risk.

1. Executive summary

This specification converts the worksheet-oriented RMM into a controlled relational model. It does not reproduce the Excel layout as a single wide table. The design separates master data, document revisions, RMM records, severity-specific assessments, controls, evidence, approvals, and audit history.

Core decision: support multiple product families, products, RMM documents, and revisions from the outset. Controlled documents remain authoritative in PLM or document control; PostgreSQL stores identifiers, revision metadata, and traceable relationships.

Design goal	Implementation
Auditability	Immutable effective revisions, approval records, and event log
Traceability	Explicit many-to-many links for harms, controls, source records, and evidence
Determinism	Validation function returns rule code, severity, entity, and message
Extensibility	S0-S4 and risk zones are criteria data, not hard-coded worksheet columns
Migration safety	Lossless staging preserves every raw Excel field and source row

1.1 Scope of deliverables

This package contains: conceptual entity design; normalized table inventory; field/key specification; relationship and cardinality map; validation strategy; deployment-ready PostgreSQL DDL; starter reference data; staging schema for Excel migration; traceability views; publication controls; test script; and deployment instructions.

1.2 Explicit assumptions

The recommended answers from the proposal are adopted: multi-RMM scope, parent-child records, normalized multi-value fields, hybrid quantitative/qualitative risk criteria, multiple harms across severities, versioned reference data, metadata-only document links, complete revision and approval history, configurable workflow roles, and a database/application validation hybrid. IEC 62304 is used in the data model; the IEC 60234 wording in the guidance tab is recorded as a source discrepancy.

2. Source-to-model interpretation

The workbook defines the RMM as part of the Risk Management File and expects traceability among identified hazards, harms, risk estimates, controls, implementation evidence, effectiveness evidence, and residual risk. The model therefore treats each of those as a governed entity or relationship rather than unstructured cell text.

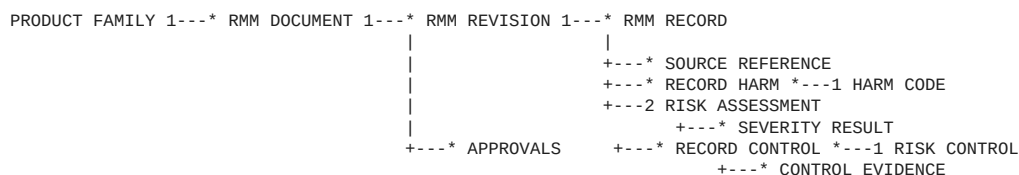
Workbook concept	Database representation	Reason
Title Page and Approvers	rmm_document, rmm_revision, revision_approval*	Separates stable document identity from revision workflow
Participant Roster	review_session, review_participant	Supports any number of sessions and participants
References	controlled_document plus relationship tables	Preserves unique controlled identifiers and locators
RMM row ID	rmm_record.business_id plus UUID key	Keeps human identifier while avoiding it as technical PK
Summary/detail rows	record_kind and parent_record_id	Enforces same-revision hierarchy
Clinical Domain	clinical_domain and record_clinical_domain	Avoids multi-value text; blocks Unknown
Hazard taxonomy	hazard_category and hazard	Controlled list with stable codes
Hazardous Situation	template plus rendered text	Uses controlled pattern while preserving final wording
Harm cell	harm_code and record_harm	Supports multiple harms and severity mappings
Initial/Residual S0-S4	risk_assessment and risk_assessment_severity	Eliminates repeated columns
D/P/I controls	risk_control and record_risk_control	Explicit control type and applicability
Evidence references	control_evidence	Separates implementation from effectiveness
Revision History	rmm_revision and audit_event	System-generated history replaces optional worksheet

3. Conceptual entity model

The conceptual model is organized into six bounded areas.

Area	Principal entities	Purpose
Portfolio	Organization, Product Family, Product, Risk Profile	Defines the product scope covered by an RMM
Document control	Controlled Document, RMM Document, RMM Revision	Holds identity, revisions, controlled references, and lifecycle
Risk criteria	Risk Criteria Set, Severity, Probability, Zone, Matrix Rule	Versions the rules supplied by the applicable RMP
Risk analysis	RMM Record, Clinical Domain, Hazard, Situation, Harm, Risk Assessment	Captures the hazard-to-harm analysis before and after controls
Risk control	Risk Control, Record Risk Control, Control Evidence	Traces requirements to implementation and effectiveness
Governance	Review Session, Participant, Approval, Audit Event	Supports review, approval, immutability, and history

3.1 Relationship spine



3.2 Record hierarchy

A summary record has no parent. A detail record must reference a summary record in the same revision. The application may display identifiers such as 1.0 and 1.1, but referential integrity uses UUIDs. This avoids identifier collisions across documents and revisions.

3.3 Risk representation

One risk_assessment row stores P1 for either initial or residual stage. One child row per severity stores P2, PoH category or value, and zone. Quantitative PoH is calculated as P1 x P2. Qualitative and hybrid methods retain level references. The physical database is not limited to five severity levels even though the source template uses S0 through S4.

4. Normalized table inventory

The production schema contains the following core tables. Staging tables are documented separately.

Table	Purpose
organization	Tenant/business scope
app_user	Actor identity snapshot and external subject
product_family	Product family master
product	Product within family
risk_profile	Family risk-profile definition
product_risk_profile	Effective-dated product/profile membership
controlled_document	Metadata for authoritative controlled records
rmm_document	Stable RMM document identity
rmm_revision	Versioned, workflow-controlled RMM content
revision_product_scope	Products and profiles covered by revision
risk_criteria_set	Versioned risk acceptability configuration
severity_level	S0-Sn definitions
probability_level	P1/P2/PoH levels and optional bounds
risk_zone	Zone meaning and acceptability
risk_matrix_rule	Severity/probability-to-zone mapping
clinical_domain	Controlled clinical domains
hazard_category	Controlled hazard category
hazard	Hazard under category
hazardous_situation_template	Controlled hazardous-situation pattern
harm_code	Hierarchical IMDRF/local harm code
rmm_record	Summary/detail analysis unit
record_clinical_domain	Record-to-domain links
record_harm	Record-to-harm and severity links
source_reference	FMEA/literature/field/design-control source
risk_assessment	Initial or residual P1
risk_assessment_severity	Severity-specific P2, PoH, and zone
risk_control	Controlled requirement identity
record_risk_control	Control applicability and type D/P/I
control_evidence	Implementation/effectiveness/rationale evidence
review_session	Dated RMM review session
review_participant	Session participant and role
approval_role	Configurable approval role
revision_approval_requirement	Required roles for a revision
revision_approval	Decision history
audit_event	Row/event change history

5. Detailed key and field specification

All transactional primary keys are UUIDs generated with pgcrypto. Human-readable codes are alternate keys. Timestamps use timestampz. Probabilities use numeric values bounded from 0 through 1 when quantitative.

5.1 Document and revision aggregate

Table	Key fields	Controlled behavior
rmm_document	rmm_document_id PK; unique family + document_number	Holds stable title, scope, classification, template metadata, current revision
rmm_revision	rmm_revision_id PK; unique document + revision and revision_number	Owns criteria set, status, CR, descriptions, predecessor, publication timestamps
controlled_document	controlled_document_id PK; unique organization + document_id + revision	Stores metadata and locator, not document binary
revision_product_scope	revision + product PK	Maps covered products and optional risk profile

5.2 Risk-analysis aggregate

Table	Key fields	Controlled behavior
rmm_record	UUID PK; unique revision + business_id	Hierarchy, hazard, situation, sequence, acceptability, software, completion
record_harm	UUID PK; unique record + harm + severity	Supports multiple harms and distinct severity associations
risk_assessment	UUID PK; unique record + stage	Exactly one initial and one residual assessment expected
risk_assessment_severity	UUID PK; unique assessment + severity	P2, PoH, and zone per severity
source_reference	UUID PK	Controlled or external reference, locator, or documented no-source reason

5.3 Risk-control aggregate

Table	Key fields	Controlled behavior
risk_control	UUID PK; unique organization + requirement_id	Reusable controlled risk-control requirement
record_risk_control	UUID PK; unique record + control + type	Captures D/P/I classification and P1/P2 impact
control_evidence	UUID PK; uniqueness across control/type/reference	Separates implementation, effectiveness, and rationale evidence

6. Cardinality and traceability rules

From	Relationship	To	Rule
RMM document	1 to many	RMM revision	One stable document has sequential revisions
RMM revision	1 to many	RMM record	All analysis content belongs to one revision
Summary record	1 to many	Detail record	Detail parent must be summary in same revision
RMM record	many to many	Clinical domain	Specific scope needs at least one domain
RMM record	many to many	Harm code	Join includes severity code
RMM record	1 to two	Risk assessment	Initial and residual required before publication
Risk assessment	1 to many	Severity result	One result per configured severity
RMM record	many to many	Risk control	Join captures D, P, or I and applicability
Record control	1 to many	Evidence	Implementation and effectiveness are distinct
RMM revision	many to many	Approval role	Requirements and decisions are separate

6.1 End-to-end traceability

The `v_rmm_traceability` view provides a human-readable chain: document and revision -> business row -> hazard category -> hazard -> hazardous situation -> sequence -> harms -> risk-control requirement IDs -> evidence document IDs. Normalized tables remain the authoritative query surface for deterministic inspection.

6.2 Summary-row semantics

The database enforces hierarchy but does not infer aggregate probabilities or zones for summary rows because aggregation logic must come from the applicable RMP. If a business requires summary aggregation, add a versioned `aggregation_method` to `risk_criteria_set` and implement a separate validated function.

7. Validation and governance design

Validation is split between deterministic database invariants and context-sensitive application rules. The SQL package implements the safety-critical structural gate and returns structured findings.

Rule	Requirement	Mechanism
RMM-001	Specific domain scope requires at least one domain	Database validation
RMM-002	Initial and residual assessments required	Publication validation
RMM-003	At least one harm required	Publication validation
RMM-004	Source or explicit no-source reason required	Publication validation
RMM-005	Completed controls need implementation and effectiveness evidence	Publication validation
RMM-006	Detail record must have same-revision summary parent	Trigger
RMM-007	Clinical domain Unknown is prohibited	CHECK constraint
RMM-008	Software identifier and class must be consistent	CHECK constraint
RMM-009	Probability values must be between 0 and 1	CHECK constraint
RMM-010	Effective revision is immutable	Trigger + status function
RMM-011	Required approval roles must be approved	Publication function
RMM-012	Hazard and situation must be controlled references	Foreign keys

7.1 Publication transaction

`publish_revision()` executes revision validation, checks required approvals, changes status to effective, records `immutable_at`, updates the document current-revision pointer, and writes a status audit event. Any failed condition aborts the transaction.

7.2 Audit strategy

The schema provides `audit_event` as the canonical event structure. In production, populate it through a service layer using authenticated actor context, or add narrowly scoped trigger functions that read a trusted session variable. Do not accept actor identity directly from untrusted client SQL.

8. Workflow and security

Lifecycle states are draft, in_review, approved, effective, superseded, and retired. Editing is allowed only before immutable_at is set. Changes to an effective RMM occur in a successor revision.

Role	Typical database privileges
Reference-data steward	Maintain controlled lists and criteria drafts
RMM author	Create and edit draft revisions and analysis records
Reviewer	Read draft and submit review findings
Approver	Create approval decision for authorized role
Publisher	Execute publication function after validation
Auditor	Read all revisions, approvals, validation results, and audit events
Migration service	Insert staging rows and invoke controlled import procedures

8.1 Recommended access controls

Use application roles mapped to PostgreSQL group roles. Revoke direct table DML from interactive users. Grant service functions the minimum required privileges. Enable row-level security only if multiple business scopes share one database and organizational separation is required. Store document locators as opaque identifiers if repository URLs or paths reveal sensitive structure.

8.2 Data classification

The RMM document stores information_classification. The application should use it for authorization, export marking, and logging policy. The database field alone does not enforce a classification handling standard.

9. Excel migration design

Migration uses a two-phase process: lossless load into `rmm_stage`, then deterministic transformation into the normalized schema. Every issue points back to `source_file`, `source_sheet`, `source_row`, and `field_name`.

Phase	Controls
Extract	Read cell values and preserve displayed text; capture exact row number and workbook identity
Stage	Insert one row per RMM worksheet row without splitting or interpretation
Profile	Match hazards, situations, domains, harm codes, probabilities, zones, and controls
Validate	Record unknown codes, malformed IDs, inconsistent software fields, missing evidence, and PoH discrepancies
Transform	Create revision, records, joins, assessments, controls, and evidence in one transaction
Reconcile	Compare staged row count, business IDs, control IDs, harms, and evidence references to normalized outputs
Approve	Run <code>validate_rmm_revision</code> and retain signed migration report before publication

9.1 Multi-value parsing policy

Do not silently split on commas because names and document titles may contain commas. Establish approved delimiters per column, preserve the original field, and record each parse decision. Unparsed tokens become `load_issue` rows and block publication.

9.2 Calculated data

For quantitative methods, compare imported PoH to $P1 \times P2$ within an approved tolerance. Preserve the imported value in staging, but store the validated canonical value in the target model. Risk zone must be derived or verified against the selected risk criteria set.

10. PostgreSQL implementation package

The companion ZIP contains ordered scripts for PostgreSQL 15 or later. The schema uses pgcrypto for UUID generation and avoids non-core dependencies.

File	Purpose
01_schema.sql	Types, 35 core tables, constraints, and indexes
02_functions.sql	PoH helper, hierarchy enforcement, immutability, validation, publication
03_views.sql	Traceability and validation reporting views
04_seed_reference_data.sql	Approval roles, hazardous situations, representative starter hazards
05_excel_staging.sql	Lossless import staging and issue table
06_smoke_tests.sql	Transaction-safe basic assertions
deploy.sql	psql deployment order with stop-on-error
rollback.sql	Development-only destructive teardown
example_queries.sql	Validation, traceability, evidence-gap, and audit queries
README.md	Assumptions and deployment notes

10.1 Deployment sequence

```
createdb rmm_db
psql -v ON_ERROR_STOP=1 -f deploy.sql rmm_db
```

10.2 Environment controls

Use separate development, validation, and production databases. Apply migrations through source control and a CI pipeline. Back up before release. Record DDL checksum, database version, migration identity, and deployment result in the change record.

11. Test and acceptance specification

Test area	Minimum acceptance evidence
DDL deployment	All scripts execute with ON_ERROR_STOP and no failed transaction
Keys and checks	Invalid probabilities, Unknown domain, and inconsistent software fields are rejected
Hierarchy	Detail without same-revision summary parent is rejected
Revision lifecycle	Effective revision content cannot be changed
Validation	Each seeded defect returns the expected RMM rule code and entity ID
Approval gate	Publication fails when a required role lacks approval
Traceability	Known sample returns expected hazard-to-evidence chain
Migration reconciliation	Source rows and normalized record counts reconcile by documented rules
Performance	Target-volume validation and primary traceability query meet application SLA
Recovery	Backup restore reproduces schema, approved revisions, and audit history

11.1 SQL verification note

The included smoke test checks helper behavior and prohibited domain content without committing data. A production project should add pgTAP or equivalent integration tests in CI and execute migrations against the exact supported PostgreSQL major version.

12. Source discrepancy and open design controls

The Risk Management Matrix tab labels the software field as IEC 62304, while the RMM - Guidance tab labels it IEC 60234. This design uses IEC 62304 because that wording appears on the actual matrix field. The discrepancy should be resolved through template governance before the schema is designated production baseline.

Item	Disposition in v1.0	Required owner decision
IEC 60234 vs 62304	Model uses IEC 62304 class A/B/C/NA	Approve correction in controlled template
Risk-zone algorithm	Versioned tables, no invented thresholds	Load rules from applicable RMP
Summary aggregation	Not inferred	Specify aggregation method if automated
CTS/CT designation	Representable through control metadata, not auto-calculated	Define approved derivation rule and evidence
Full code catalogs	Starter data only	Load from authoritative controlled source
Electronic signature	Approval records included; not claimed as regulated e-signature	Integrate validated identity/signature service if required

13. Workbook-guidance traceability matrix

Guidance requirement	Schema control
Unique summary/detail identifier	rmm_record.business_id unique in revision; hierarchy trigger
FMEA/literature/design/field/fault-tree source	source_reference with document and locator detail
Clinical domain; Single/All; no Unknown	domain_scope plus join; Unknown CHECK
Hazard from controlled list	hazard foreign key
Situation from controlled list	hazardous_situation_template foreign key
Sequence starts from hazard or Normal Condition	Stored narrative; application rule recommended
Multiple harms permitted	record_harm many-to-many relationship
P1 before and after controls	risk_assessment stage initial/residual
P2 and zone for S0-S4	risk_assessment_severity
Quantitative PoH equals P1 x P2	compute_poh; migration reconciliation
Initial and residual acceptability	rmm_record boolean determinations
Serious injury premitigation determination	rmm_record.premitigation_serious_injury
Software item and classification	software consistency CHECK
D/P/I control types and requirement IDs	record_risk_control and risk_control
Implementation verification	control_evidence implementation
Effectiveness verification/validation	control_evidence effectiveness
Risk-reduction endpoint complete	control_activities_complete
Review sessions and participants	review_session and review_participant
Minimum approval functions	configurable seeded approval roles
Revision history	rmm_revision plus audit_event

14. Recommended implementation backlog

Priority	Work item	Exit criterion
P0	Approve logical model and resolve standards discrepancy	Signed design baseline
P0	Load authoritative risk criteria and controlled catalogs	Versioned seed package with source IDs
P0	Build migration profiler for one representative RMM	Complete issue report and reconciliation
P1	Implement API commands and role authorization	No direct client DML
P1	Add full audit-event capture with trusted actor context	Actor and before/after values verified
P1	Build review/approval workflow and publication gate	Effective revision is immutable
P1	Create traceability and validation UI/export	Rule-level findings downloadable
P2	Add risk-profile and CTS/CT reporting after rules are approved	Verified against controlled policy
P2	Performance/load testing at portfolio scale	SLA and recovery objectives met

14.1 Definition of done

The design is complete when the source discrepancy is dispositioned, controlled reference catalogs and risk-rules are loaded from authoritative documents, migration reconciliation passes, database and application validation produce no blocking findings, required approvals are recorded, and publication creates an immutable effective revision.

Appendix A. Physical naming and data-type conventions

Convention	Rule
Names	snake_case; singular table names; explicit relationship-table names
Primary keys	_id UUID, except audit_event bigserial
Foreign keys	Same name as referenced primary key
Business identifiers	Text alternate keys with scoped UNIQUE constraints
Timestamps	timestamptz in UTC
Probability	numeric constrained to [0,1]; qualitative levels by FK
Enumerations	PostgreSQL enum for stable closed sets; tables for governed vocabularies
Documents	Metadata and repository locator only; no BLOB by default
Deletes	Cascade only within a draft revision aggregate; master data is inactivated
Text	Narrative preserved; structured identifiers separated from narrative

Appendix B. Example query patterns

```
-- Blocking findings
SELECT * FROM rmm.validate_rmm_revision(:revision_id);

-- Full traceability
SELECT * FROM rmm.v_rmm_traceability
WHERE document_number = :doc AND revision = :rev
ORDER BY business_id;

-- Publish after approvals
SELECT rmm.publish_revision(:revision_id, :actor_user_id);
```

Appendix C. Deliverable boundaries

This is a database design and SQL implementation baseline. It does not claim validation under a specific regulated software lifecycle, does not encode undocumented risk thresholds, and does not replace approval of the applicable Risk Management Plan or Product Safety Risk Acceptability Policy. Those controlled inputs must be loaded and verified before production use.